

# Guide de Présentation Orale

Synthèse ENG261 — Tony NASR

## **Application du Machine Learning pour la Détection Intelligente des Cyberattaques dans les API Web**

Ce document contient : (1) le script complet à dire pendant les 5 minutes de présentation (7 slides, incluant la nouvelle page Sommaire), et (2) 10 questions probables du jury avec leurs réponses prêtes à l'emploi.

---

# Partie 1 — Script de la Présentation (5 minutes)

## Slide 1 — Page de Titre

■ *Durée conseillée : 30 secondes*

« Bonjour, je m'appelle Tony NASR, étudiant en Génie Informatique à le CNAM Liban. Ma synthèse bibliographique, encadrée par Dr. Amal Kobeissi et Dr. Ahmad El Hajjar, porte sur l'application du Machine Learning pour détecter intelligemment les cyberattaques dans les API Web. »

---

## Slide 2 — Sommaire (nouvelle slide)

■ *Durée conseillée : 20 secondes*

« Voici le plan de ma présentation. Je vais d'abord introduire le contexte et la problématique, puis je présenterai l'état de l'art avec les principaux algorithmes étudiés. Ensuite, je montrerai un tableau comparatif des résultats, et je terminerai par un bilan et une conclusion. »

---

## Slide 3 — Introduction & Contexte

■ *Durée conseillée : 1 minute*

« Aujourd'hui, les applications web et les API sont partout — banques, hôpitaux, e-commerce. Ça les rend très attractives pour les hackers. Des attaques comme l'injection SQL et le XSS figurent depuis des années en tête du classement OWASP.

Le problème avec les systèmes classiques, c'est qu'ils se basent sur des signatures fixes. Ils sont limités face aux attaques modernes, ils ne peuvent pas détecter les nouvelles attaques zero-day, ils bloquent parfois du trafic légitime, et leur maintenance est lente et coûteuse.

C'est là qu'intervient le Machine Learning : un système qui apprend automatiquement à reconnaître les attaques. »

---

## Slide 4 — État de l'Art (Algorithmes & Résultats)

■ *Durée conseillée : 1 minute 30*

« J'ai étudié quatre grandes approches algorithmiques.

D'abord les CNN — très efficaces pour détecter les injections SQL et le XSS. Le meilleur résultat : 99,9% de précision sur 4,48 millions de requêtes réelles.

Ensuite les LSTM et les modèles hybrides CNN-LSTM, qui captent les attaques progressives dans le temps, comme les DDoS — avec 97,57% de détection et 100 000 flux traités en 27 secondes.

Les algorithmes de ML supervisé comme Decision Tree et Random Forest restent très compétitifs — entre 93 et 97% — avec beaucoup moins de ressources.

Et enfin, des WAF intelligents basés sur ML ont été déployés en production réelle — jusqu'à 1 milliard de requêtes par jour — avec 99,62% d'exactitude. »

---

## Slide 5 — Tableau Comparatif

■ *Durée conseillée : 45 secondes*

« Ce tableau résume les résultats des 8 articles analysés. On voit clairement que tous les modèles dépassent 93%, et que les approches Deep Learning comme EP-CNN et LSTM/RNN atteignent presque 100%. Les chiffres en vert indiquent les meilleurs résultats. Ce qui est remarquable, c'est que même les algorithmes de ML supervisé comme Decision Tree restent très performants en conditions réelles. »

---

## Slide 6 — Bilan & Conclusion

■ *Durée conseillée : 1 minute*

« En conclusion, le Machine Learning représente une avancée majeure pour la cybersécurité des API web. Plus de 97% de taux de détection sur 4 types d'attaques différents — c'est un résultat très significatif.

Les points forts : ces systèmes s'adaptent aux nouvelles menaces sans mise à jour manuelle, et ont déjà prouvé leur efficacité en production.

Mais des défis restent : comment généraliser ces modèles à des environnements inconnus ? Comment gérer le déséquilibre entre trafic normal et malveillant ? Et comment résister aux techniques d'évasion avancées ?

Le ML et le DL sont clairement l'avenir de la sécurité applicative. »

---

## Slide 7 — Merci

■ *Durée conseillée : 15 secondes*

« Je vous remercie pour votre attention. Je suis disponible pour répondre à vos questions. »

### Résumé du Minutage

| Slide | Contenu                 | Durée             |
|-------|-------------------------|-------------------|
| 1     | Titre                   | 30 sec            |
| 2     | Sommaire                | 20 sec            |
| 3     | Introduction & Contexte | 1 min             |
| 4     | État de l'Art           | 1 min 30          |
| 5     | Tableau Comparatif      | 45 sec            |
| 6     | Bilan & Conclusion      | 1 min             |
| 7     | Merci                   | 15 sec            |
|       | <b>TOTAL</b>            | <b>~5 minutes</b> |

Conseil : ne lis pas les slides mot pour mot — regarde le jury, parle lentement, et utilise les slides comme support visuel derrière toi.

## Partie 2 — Questions Probables du Jury & Réponses

Voici 10 questions que les docteurs pourraient te poser après ta présentation, avec des réponses claires et directes à utiliser.

### Q1. Pourquoi avoir choisi le Machine Learning plutôt que les méthodes traditionnelles de sécurité (signatures, règles fixes) ?

Les méthodes traditionnelles basées sur des signatures fixes ne détectent que les attaques déjà connues. Elles échouent face aux attaques zero-day et aux variantes obfusquées. Le Machine Learning apprend des patterns dans les données et peut généraliser à des attaques jamais vues auparavant, ce qui le rend beaucoup plus adaptatif.

### Q2. Quelle est la différence entre CNN et LSTM, et pourquoi utiliser l'un plutôt que l'autre ?

Le CNN est excellent pour détecter des motifs locaux dans une requête HTTP, comme une syntaxe SQL suspecte ou un script malveillant dans le XSS — c'est pour ça qu'il est très performant sur SQLi et XSS. Le LSTM, lui, capte les dépendances temporelles, c'est-à-dire l'évolution d'une séquence de requêtes dans le temps — ce qui le rend plus adapté aux attaques DDoS qui se déroulent sur plusieurs requêtes successives.

### Q3. Pourquoi le Decision Tree obtient-il des résultats proches du Deep Learning alors qu'il est plus simple ?

Le Decision Tree fonctionne très bien quand les caractéristiques discriminantes des attaques sont relativement simples à séparer, comme certains motifs de SQLi ou XSS. Il est aussi plus rapide et plus interprétable. Le Deep Learning prend l'avantage surtout quand les données sont très volumineuses et complexes, comme dans le cas d'EP-CNN avec 4,48 millions de logs.

### Q4. Comment gère-t-on le problème du déséquilibre des classes (peu de trafic malveillant, beaucoup de trafic normal) ?

C'est un défi mentionné dans plusieurs articles de ma synthèse. Les techniques couramment utilisées incluent le sur-échantillonnage des attaques (oversampling, comme SMOTE), le sous-échantillonnage du trafic normal, l'ajustement des poids de classes pendant l'entraînement, et l'utilisation de métriques adaptées comme le F1-score plutôt que la simple exactitude, qui peut être trompeuse sur des données déséquilibrées.

#### **Q5. Qu'est-ce qu'une attaque zero-day, et comment le ML peut-il la détecter sans l'avoir jamais vue ?**

Une attaque zero-day est une attaque qui exploite une vulnérabilité inconnue, donc absente des bases de signatures. Le ML ne mémorise pas des signatures exactes : il apprend des caractéristiques statistiques et structurelles du trafic malveillant en général. Si une nouvelle attaque partage des caractéristiques similaires aux attaques connues — une structure de requête anormale, par exemple — le modèle peut la détecter par généralisation, même sans l'avoir vue exactement.

#### **Q6. Quelles sont les limites actuelles de ces approches basées sur le Machine Learning ?**

Les limites principales sont : la généralisation difficile à des environnements ou trafics différents de ceux utilisés à l'entraînement, la sensibilité au déséquilibre des classes, le risque de faux positifs qui bloquent du trafic légitime, et la vulnérabilité aux techniques d'évasion où l'attaquant modifie légèrement sa requête pour tromper le modèle (adversarial attacks).

#### **Q7. Est-ce que ces modèles sont vraiment utilisables en production réelle, avec du trafic à grande échelle ?**

Oui, plusieurs articles le démontrent. Kim et al. ont déployé leur système AI-IDS dans un centre financier traitant 1 milliard de requêtes par jour via Docker. Durmuskaya et Bayrakli ont testé leur WAF basé sur Decision Tree avec mitmproxy sur plus de 36 000 requêtes réelles. Cela montre que ces solutions ne sont pas seulement théoriques, mais déjà testées en conditions réelles.

#### **Q8. Pourquoi avoir choisi ces 8 articles en particulier pour ta synthèse ?**

J'ai mené une recherche documentaire sur IEEE Xplore, SpringerLink, MDPI et Google Scholar avec des mots-clés ciblés. J'ai sélectionné des publications à comité de lecture, entre 2019 et 2026, en privilégiant la diversité des types d'attaques (SQLi, XSS, DDoS, LFI) et des approches algorithmiques (CNN, LSTM, algorithmes classiques, WAF intégrés), pour avoir une vue d'ensemble représentative du domaine.

#### **Q9. Quelle serait la prochaine étape si tu devais continuer ce travail (mémoire ou projet futur) ?**

La prochaine étape logique serait l'intégration réelle de ces modèles dans un WAF en environnement de production, avec un focus sur la robustesse face aux techniques d'évasion et la réduction des faux positifs. On pourrait aussi explorer des architectures hybrides combinant plusieurs algorithmes, ou des techniques d'explicabilité (XAI) pour comprendre les décisions du modèle, ce qui est important pour la confiance des équipes de sécurité.

**Q10. Quelle est la différence entre exactitude (accuracy) et F1-score, et pourquoi les deux sont mentionnés dans ton tableau ?**

L'exactitude mesure le pourcentage global de prédictions correctes, mais elle peut être trompeuse quand les classes sont déséquilibrées — un modèle qui prédit toujours 'trafic normal' peut avoir une exactitude élevée tout en étant inutile. Le F1-score combine la précision et le rappel, et donne une mesure plus fiable de la capacité du modèle à détecter correctement les attaques sans trop de faux positifs ni de faux négatifs. C'est pourquoi les deux métriques sont complémentaires dans l'évaluation.

*Conseil final : si une question te surprend, n'hésite pas à dire « C'est une excellente question, d'après les articles que j'ai étudiés... » avant de répondre. Cela montre que tu maîtrises ton sujet même face à l'imprévu.*